



Centrifuge PR335 - ShareManager Audit Report

Prepared by [Burra Security](#)

Version 1.0

Researchers

Alex Filippov

fuzious

Taridoku

September 1, 2026

Contents

1	About Burra Security	2
2	Disclaimer	2
3	Risk Classification	2
4	Protocol Summary	2
5	Audit Scope	2
6	Executive Summary	3
7	Findings	4
7.1	Low Risk	4
7.1.1	Freezing ShareManager disables hub-driven revocations for the affected share token	4
7.2	Informational	5
7.2.1	ShareManager is missing from the CLAUDE tree and its registry dependency from the diagram	5
7.2.2	Maximum approval unnecessarily restricts compatible share-token implementations	5
7.2.3	ShareManager revoke events obscure the affected investor	5
7.2.4	ShareManager executes token operations for zero-share calls	6

1 About Burra Security

Burra Security offers security auditing and advisory services with a special focus on cross-chain and interoperability protocols and their integrations. Learn about us at burrasec.com.

2 Disclaimer

A smart contract security review can never verify the complete absence of vulnerabilities. This is a time, resource, and expertise-bound effort where we try to find as many vulnerabilities as possible. We can not guarantee 100% security after the review or even if the review will find any vulnerabilities. Subsequent security reviews, bug bounty programs, and on-chain monitoring are recommended.

3 Risk Classification

	Impact: High	Impact: Medium	Impact: Low
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

4 Protocol Summary

`ShareManager` is a spoke-side balance sheet manager for Hub-driven share issuance and revocation. It serves holdings tracked outside the protocol — investments on chains where Centrifuge is not live — and a single deployment is shared across every pool.

Every operation arrives as a manager call from the Hub through the Envoy, so it matures through Hub policy before execution and no local wallet holds any permission. The `fromHub` entrypoint decodes a payload into a share class, account, and share amount, then dispatches one of two actions: `Issue` mints through `Spoke.issue`, while `Revoke` force-transfers the investor's shares into the manager, approves `Spoke`, and burns them via `Spoke.revoke`.

The contract holds three immutables and no storage: the Envoy that authorizes it, `Spoke` for share balance operations, and `ISpokeRegistry` to resolve the ERC-20 share token for each pool and share class. It carries no wards of its own, deferring accounting, transfer-hook enforcement, and escrow updates to core `Spoke`.

It sits in `src/managers/spoke/` alongside balance sheet managers such as `OnOffRamp` and `QueueManager`, turning a single Hub-side governance decision into concrete token operations on whichever chain hosts the share class.

5 Audit Scope

The following files from PR #335 are in the scope of the audit:

```
src/
├── managers/
│   └── spoke/
│       ├── interfaces/
│       │   └── IShareManager.sol
│       ├── README.md
│       └── ShareManager.sol
```

6 Executive Summary

Over the course of 2 days, the Burra Security team conducted an audit on the [Centrifuge PR335 - ShareManager](#) smart contracts provided by [Centrifuge](#). In this period, a total of 5 issues were found.

Summary

Project Name	Centrifuge PR335 - ShareManager
Repository	protocol-internal
Commit	871a285fe1ba...
Audit Timeline	Aug 20th - Aug 21st
Methods	Manual Review

Issues Found

Critical Risk	0
High Risk	0
Medium Risk	0
Low Risk	1
Informational	4
Gas Optimizations	0
Total Issues	5

Summary of Findings

[L-1] Freezing ShareManager disables hub-driven revocations for the affected share token	Resolved
[I-1] ShareManager is missing from the CLAUDE tree and its registry dependency from the diagram	Resolved
[I-2] Maximum approval unnecessarily restricts compatible share-token implementations	Resolved
[I-3] ShareManager revoke events obscure the affected investor	Resolved
[I-4] ShareManager executes token operations for zero-share calls	Resolved

7 Findings

7.1 Low Risk

7.1.1 Freezing `ShareManager` disables hub-driven revocations for the affected share token

Target: `ShareManager.sol`, `Spoke.sol`, `BaseTransferHook.sol`, `ActionBatchers.sol`

Severity:

- Impact: Low
- Likelihood: Low

Description: `ShareManager` first force-transfers an investor's shares into itself and then calls `Spoke.revoke`, which performs an ordinary hook-checked transfer from `ShareManager` to `Spoke`. Because deployment does not Root-endorse `ShareManager`, an authorized hook ward or token-specific hook manager can freeze it. Every shipped hook rejects the second transfer when its source is frozen, causing all hub-driven revocations for that share token to revert until the singleton is unfrozen. The transaction rolls back without stranding the investor's shares, and no permissionless freeze path exists, so this is privileged-role hardening rather than an untrusted exploit.

Recommended Mitigation: Endorse `ShareManager` alongside the other transient share custodians and assert the endorsement during deployment. For existing deployments, clear any already-stored freeze bit because endorsement prevents future canonical freezes but does not remove an existing one. Since endorsement also makes `ShareManager` pass target-membership checks, document direct transfers to it as requiring administrative recovery.

Centrifuge: Fixed in [centrifuge/protocol-internal#350](#)

BurraSec: Fix looks good.

7.2 Informational

7.2.1 `ShareManager` is missing from the CLAUDE tree and its registry dependency from the diagram

Target: CLAUDE.md:85, docs/architecture/managers/spoke-managers.puml:21-22

Severity: Informational

Description: The PR updates the spoke-manager README and PlantUML diagram, but `ShareManager.sol` is absent from the CLAUDE.md repository tree. The diagram includes `ShareManager --> ISpoke` but omits its direct `ISpokeRegistry` dependency, which is a third immutable and is used to resolve the revoke token.

Recommended Mitigation: Consider adding `ShareManager.sol` next to `QueueManager.sol` in the CLAUDE tree and adding `ShareManager --> ISpokeRegistry` to the diagram.

Centrifuge: [centrifuge/protocol-internal#350](#)

BurraSec: Fix looks good

7.2.2 Maximum approval unnecessarily restricts compatible share-token implementations

Target: src/managers/spoke/ShareManager.sol:50

Severity: Informational

Description: `ShareManager` approves `Spoke` for `type(uint256).max` before each revocation:

```
SafeTransferLib.safeApprove(token, address(spoke), type(uint256).max);
```

The protocol supports custom share-token implementations through the registrar abstraction. Some ERC20 implementations, such as mainnet USDT, require the current allowance to be zero before setting another non-zero allowance and do not consume a maximum allowance. For such tokens, the first revocation succeeds but the next `approve(max)` reverts.

`ShareManager` therefore imposes an additional and unnecessary compatibility constraint on custom share-token implementations.

Recommended Mitigation: Consider approving exactly shares:

```
SafeTransferLib.safeApprove(token, address(spoke), shares);
```

Alternatively, consider explicitly documenting that supported share tokens must allow repeated non-zero maximum approvals.

Centrifuge: [centrifuge/protocol-internal#350](#)

BurraSec: Fix looks good

7.2.3 `ShareManager` revoke events obscure the affected investor

Target: `ShareManager.sol`, `Spoke.sol`, `ISpoke.sol`

Severity: Informational

Description: A `ShareManager` revocation first emits `TransferSharesFrom` with the investor as `from`, but the terminal `Spoke.Revoke` event records both `sender` and `from` as the `ShareManager` singleton because it is the immediate caller and token holder. `ShareManager` emits no semantic event of its own. Indexers treating `Revoke` as the canonical cancellation event therefore cannot identify the affected investor without correlating the preceding transfer or decoding the Envoy payload from the same transaction.

Recommended Mitigation: Emit an issue/revoke event from `ShareManager` containing the pool, share class, original account, and share amount, or explicitly document the event-correlation requirement for indexers.

Centrifuge: Fixed in [centrifuge/protocol-internal#350](#)

BurraSec: Fix looks good

7.2.4 `ShareManager` executes token operations for zero-share calls

Target: `ShareManager.sol`, `Spoke.sol`, `SnapshotQueue.sol`

Severity: Informational

Description: `ShareManager.fromHub` accepts a zero share amount. Although `SnapshotQueue.queueShares` treats zero as a no-op, issuance still calls the registrar's zero-value mint path, while revocation performs a zero-value privileged transfer, grants `Spoke` a maximum allowance, and enters the zero-value burn path. These calls do not change supply or queued issuance, but they execute avoidable hooks and emit operational events; a nominal no-op governance action can also revert because of token-specific behavior.

Recommended Mitigation: Reject `shares == 0` in `ShareManager.fromHub` before dispatching either action, using an explicit empty-amount error.

Centrifuge: Fixed in [centrifuge/protocol-internal#350](https://github.com/centrifuge/protocol-internal/issues/350)

BurraSec: Fix looks good